Lecture 8

Cloud Security

Materials curated from CompTia and ISACA

Materials Covered:

- Cloud Computing & Virtualization Concepts
- Cloud Computing Risks & Threats
- Cloud Cybersecurity Solutions

Cloud Computing & Virtualization Concepts

Materials curated from CompTia

Cloud and Digital Collaboration

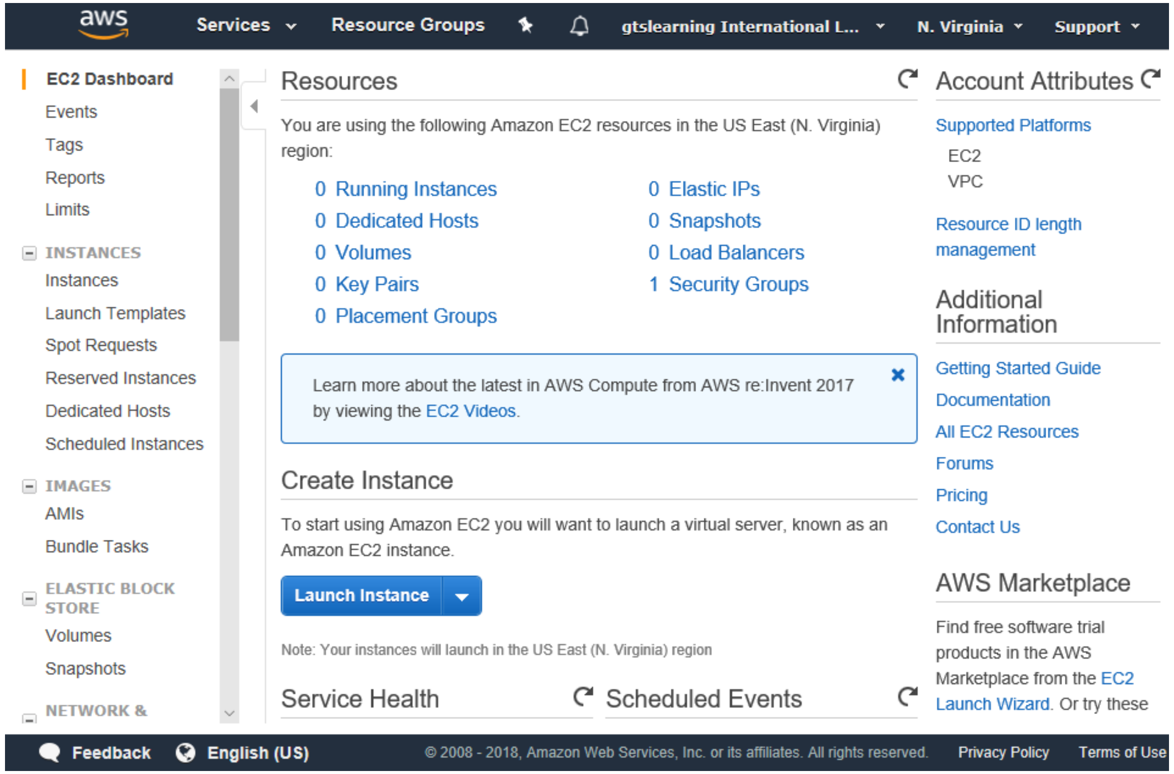
- Definition of Cloud Computing according to NIST and Cloud Security Alliance (CSA)

    "model for enabling convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction"

Cloud Deployment Models

- Public (multi-tenant)
  - Cloud service providers (CSPs)
  - Shared between subscribers
  - Multi-cloud
- Hosted private
  - Private instance operated by a CSP but dedicated to a single customer
- Private
  - Wholly owned and operated by the organization
  - On-premises vs. off-premises
- Community
- Hybrid

Cloud Service Models



Screenshot used with permission from Amazon.com.

- Anything as a service (XaaS)
- Infrastructure as a Service (IaaS)
  - Unconfigured compute, storage, and network resources
- Software as a Service (SaaS)
  - Fully developed applications
- Platform as a Service (PaaS)
  - Pre-configured OS and database/middleware instances

Anything as a Service

- Specific IaaS, PaaS, or SaaS solutions for business needs
- Security in the cloud
- Security of the cloud
- Cloud responsibility matrix

Responsibility	IaaS	PaaS	SaaS
IAM	You	You	You (using CSP toolset)
Data security (CIA attributes/backup)	You	You	You/CSP/Both
Data privacy	You/CSP/Both	You/CSP/Both	You/CSP/Both
Application code/configuration	You	You	CSP
Virtual network/firewall	You	You/CSP	CSP
Middleware (database) code/configuration	You	CSP	CSP
Virtual Guest OS	You	CSP	CSP
Virtualization layer	CSP	CSP	CSP
Hardware layer (compute, storage, networking)	CSP	CSP	CSP

Security as a Service

- Consultants
  - Third-party expertise and perspective
- Managed Security Services Provider (MSSP)
  - Turnkey security solutions
- Security as a Service (SECaaS)
  - Cloud-deployed security assessment and analysis
  - Cyber threat intelligence and machine learning analytics

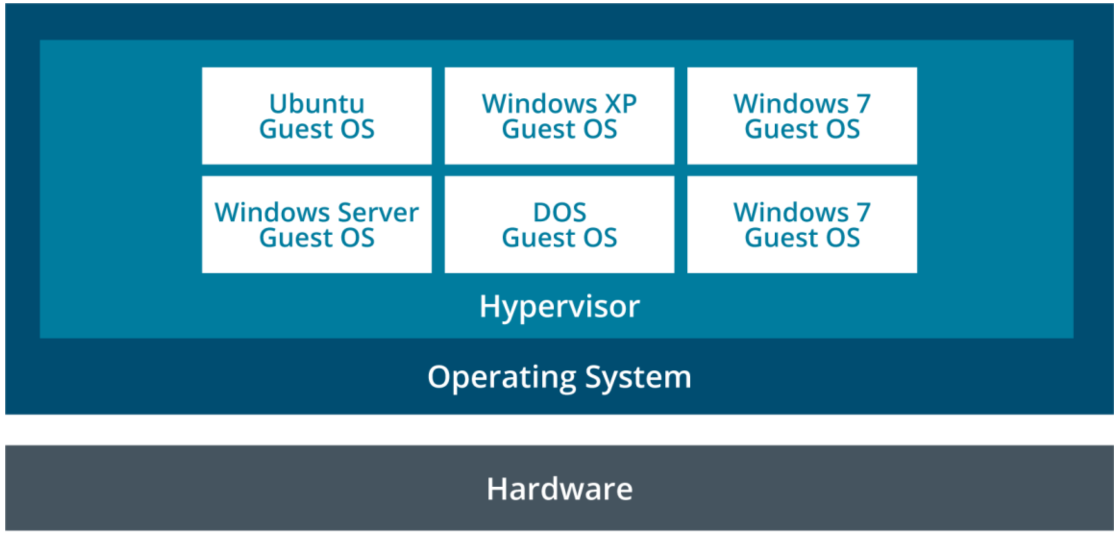
Virtualization

- Virtualization according to ISACA glossary,

  “The process of adding a “guest application” and data onto a “virtual server,” recognizing that the guest application will ultimately part company from this physical server.”

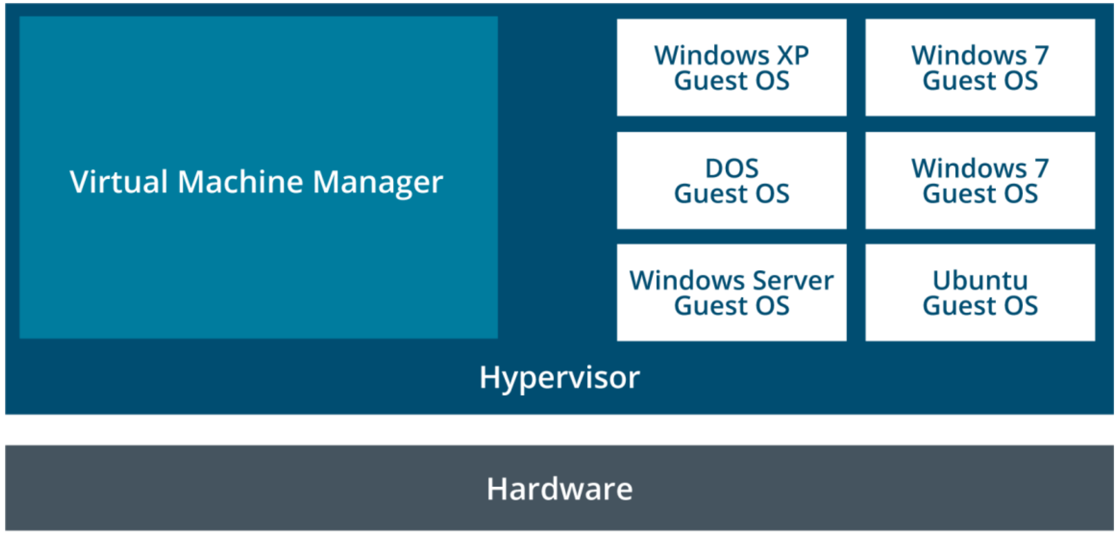
- It involves multiple guests coexisting on the same server in isolation of one another.
- Virtualization and service-oriented architectures (SOAs) act as key enablers for cloud computing.

Virtualization Technologies and Hypervisor Types



- Virtualization platform
  - Host hardware
  - Hypervisor/Virtual Machine Monitor (VMM)
  - Guest operating systems, Virtual Machines (VM), or instances

- Type II hypervisors (host-based)
- Type I hypervisors (bare metal)



Virtual Desktop Infrastructure and Thin Clients

- Virtual Desktop Infrastructure (VDI)
- Storing images of clients (OS + applications) on a central server
- Virtual Desktop Environment (VDE) images are loaded by thin clients
- Allows for low-power client devices
- Centralizes control over client desktops
- Allows for almost completely hosted IT infrastructure

Cloud Computing Risks & Threats

Materials curated from ISACA

Cloud and Digital Collaboration

- Safety and security of the data are entrusted in the care of cloud providers.
- It is attractive to attackers because of the massive concentrations of data.
- Many cloud providers are ISO 27001 or FIPS 140-2 certified.
- Organizations must ensure that their cloud provider has a security system in place equivalent to or better than the organization’s own security practice.
- Organizations can request audits of the cloud provider, which should cover the facilities, networks, hardware and operating systems within the cloud infrastructure.

Cloud Computing Risks According to NIST

- Loss of Governance
- Lock-in
- Isolation Failure
- Compliance
- Management Interface Compromise
- Data Protection
- Insecure or Incomplete Data Deletion
- Malicious Insider

Cloud Computing Risks According to NIST

- Loss of Governance

The client usually relinquishes some level of control to the cloud provider, which may affect security, especially if the service level agreements (SLAs) leave a gap in security defenses.

- Lock-in

It can be difficult for a client to migrate from one provider to another, which creates a dependency on a particular cloud provider for service provision.

- Isolation Failure

The failure of mechanisms that separate storage, memory, routing and reputation between different tenants can create risk.

Cloud Computing Risks According to NIST

- Compliance

Migrating to the cloud may create a risk in the organization achieving certification if the cloud provider cannot provide compliance evidence.

- Management and Interface Compromise

The customer management interface can pose an increased risk because it is accessed through the Internet and mediates access to larger sets of resources.

- Data Protection

It may be difficult for clients to check the data handling procedures of the cloud provider.

Cloud Computing Risks According to NIST

- Insecure or Incomplete Data Deletion

Because of the multiple tenancies and the reuse of hardware resources, there is a greater risk that data are not deleted completely, adequately or in a timely manner.

- Malicious Insider

Cloud architects have extremely high-risk roles. A malicious insider could cause a great degree of damage.

Virtualization

Advantages	Disadvantages
• Server hardware costs may decrease for both server builds and server maintenance. • Multiple OSs can share processing capacity and storage space that often goes to waste in traditional servers, thereby reducing operating costs. • The physical footprint of servers may decrease within the data center. • A single host can have multiple versions of the same OS, or even different OSs, to facilitate testing of applications for performance differences. • Creation of duplicate copies of guests in alternate locations can support business continuity efforts. • Application support personnel can have multiple versions of the same OS, or even different OSs, on a single host to more easily support users operating in different environments. • A single machine can house a multitier network in an educational lab environment without costly reconfigurations of physical equipment. • Smaller organizations that had performed tests in the production environment may be better able to set up logically separate, cost-effective development and test environments. • If set up correctly, a well-built, single access control on the host can provide tighter control for the host's multiple guests.	• Inadequate configuration of the host could create vulnerabilities that affect not only the host, but also the guests. • Exploits of vulnerabilities within the host's configuration, or a DoS attack against the host, could affect all of the host's guests. • A compromise of the management console could grant unapproved administrative access to the host's guests. • Performance issues of the host's own OS could impact each of the host's guests. • Data could leak between guests if memory is not released and allocated by the host in a controlled manner. • Insecure protocols for remote access to the management console and guests could result in exposure of administrative credentials.

Source: ISACA, *CISA Review Manual 26th Edition*, USA, 2015, figure 5.14

The CSA list of the top cloud computing threats*.

- Data breaches
- Data loss
- Account hijacking
- Insecure application programming interfaces (APIs)
- Denial-of-service (DoS)
- Malicious insiders
- Abuse of cloud services
- Insufficient due diligence
- Shared technology issues

*CSA (2013), The Notorious Nine: Cloud Computing Top Threats in 2013.

Cloud Cybersecurity Solutions

Materials curated from CompTia

Top Security Benefits of Cloud Computing

- Market Driven
- Scalability
- Cost-effective
- Timely and Effective Updates
- Audit and Evidence

Top Security Benefits of Cloud Computing

- Market drive

Because security is a top priority for most cloud customers, cloud providers have a strong driver for increasing and improving their security practices.

- Scalability

Cloud technology allows for the rapid reallocation of resources, such as those for filtering, traffic shaping, authentication and encryption, to defensive measures.

- Cost-effective

All types of security measures are cheaper when implemented on a large scale. The concentration of resources provides for cheaper physical perimeter and physical access control and easier and cheaper application of many security-related processes.

Materials curated from ISACA

Top Security Benefits of Cloud Computing

- Timely and Effective Updates

Updates can be rolled out rapidly across a homogeneous platform.

- Audit and Evidence

Cloud computing can provide forensic images of virtual machines, which results in less downtime for forensic investigations.

Cloud Security Controls

- Same types of security controls
  - IAM, endpoint protection, resource policies, firewalls, logging, …
- Cloud native controls vs. third-party solutions
  - CSP web console, CLI, and API
  - Vendor virtual instances
- Application security and IAM
  - Secure development/coding
  - Security accounts/groups/roles
- Secrets management
  - Block use of root account
  - Use MFA for privileged accounts
  - Protect API keys

Cloud Compute Security

- Compute
  - Processing resources for cloud workloads (CPU and RAM)
  - Virtual machines and containers
  - Dynamic resource allocation
- Container security
- API inspection and integration
  - Number of requests
  - Latency
  - Error rates
  - Unauthorized and suspicious endpoints
- Instance awareness
  - Logging and monitoring to mitigate cloud sprawl

Cloud Storage Security

- Storage
  - Persistent storage capacity
  - Performance characteristics for storage tiers
  - Input/output operations per second (IOPS)
- Permissions and resource policies
  - JavaScript Object Notation (JSON)
- Encryption
  - Symmetric media encryption key
  - CSP-managed keys versus customer-managed
  - Separation of duties for CSP-managed keys

```
"Statement": [ {
 "Action": [
   "*"
 ],
 "Effect": "Allow",
 "Principal": "*",
 "Resource":
"arn:aws:s3:::515support-
courses-data/*"
} ]
```

High Availability

- High availability
  - Virtualization layer provisions dynamic allocation and redundancy
  - 99.99%+ uptime
- Replication
  - Copying data between media, servers, or sites
  - Performance tiers
- High availability across zones
  - Local
  - Regional
  - Geo-redundant storage (GRS)

Cloud Networking Security

- Cloud networking types
  - Operating and managing cloud systems
  - Virtual networks between VMs and containers within the cloud
  - Virtual networks publishing cloud services
- Virtual private clouds (VPCs)
  - Segmented virtual networks
  - Can contain multiple IPv4 and IPv6 subnets
- Public and private subnets
  - Internet gateway and default route
  - Public IP addresses
  - NAT gateway
  - VPN

VPCs and Transit Gateways

- Routing between subnets
  - Can use traditional access control lists
  - Can use vendor security appliance instances
- Multiple VPCs for segmentation
  - Between VPCs in the same account
  - Between different accounts
  - To on-premises networks
- Peering relationships
  - One-to-one connections
- Transit gateways
  - Virtual router

VPC Endpoints

- Publishing a service over cloud internal network
- Avoids exposing traffic to the Internet
- Gateway endpoint
  - Connect instances to S3 and DynamoDB services
  - Added as route
- Interface endpoint
  - AWS PrivateLink
  - Service VPC or default Amazon service published with a DNS name
  - VPC endpoint interface added to each service consumer VPC
  - Instances within the consumer VPC access the service via the VPC endpoint interface

Cloud Firewall Security

- Need for segmentation
  - Load balancing workloads
  - Isolating data processing
  - Compartmentalizing data access
- Open Systems Interconnection (OSI) layers
  - Network layer (layer 3)
  - Transport layer (layer 4)
  - Application layer (layer 7)
- Cloud native versus vendor controls
  - Deploy host-based firewall within instance
  - Deploy vendor firewall/security appliance as instance
  - Transaction and volume costs for cloud native solutions

VM Escape Protection

- Reduce impact of successful exploits
- Ensure careful placement of VM services on hosts/within network
- Respect security zones (DMZ)

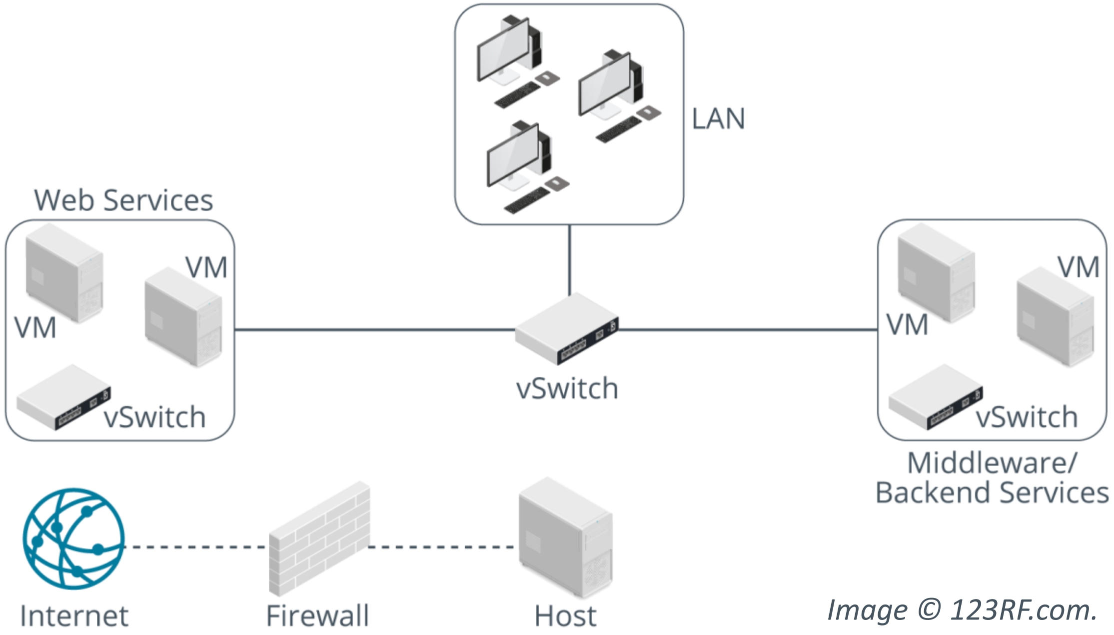
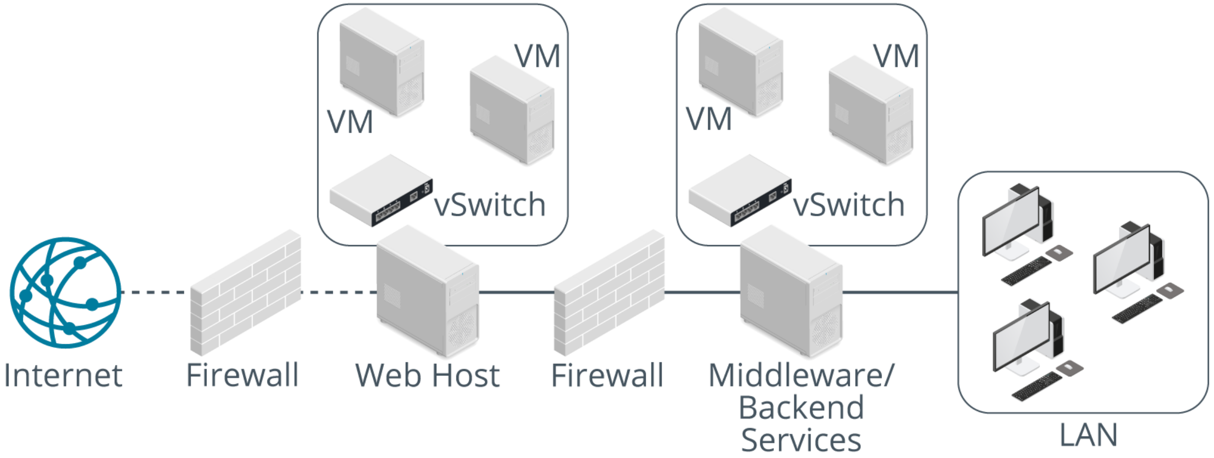


Image © 123RF.com.



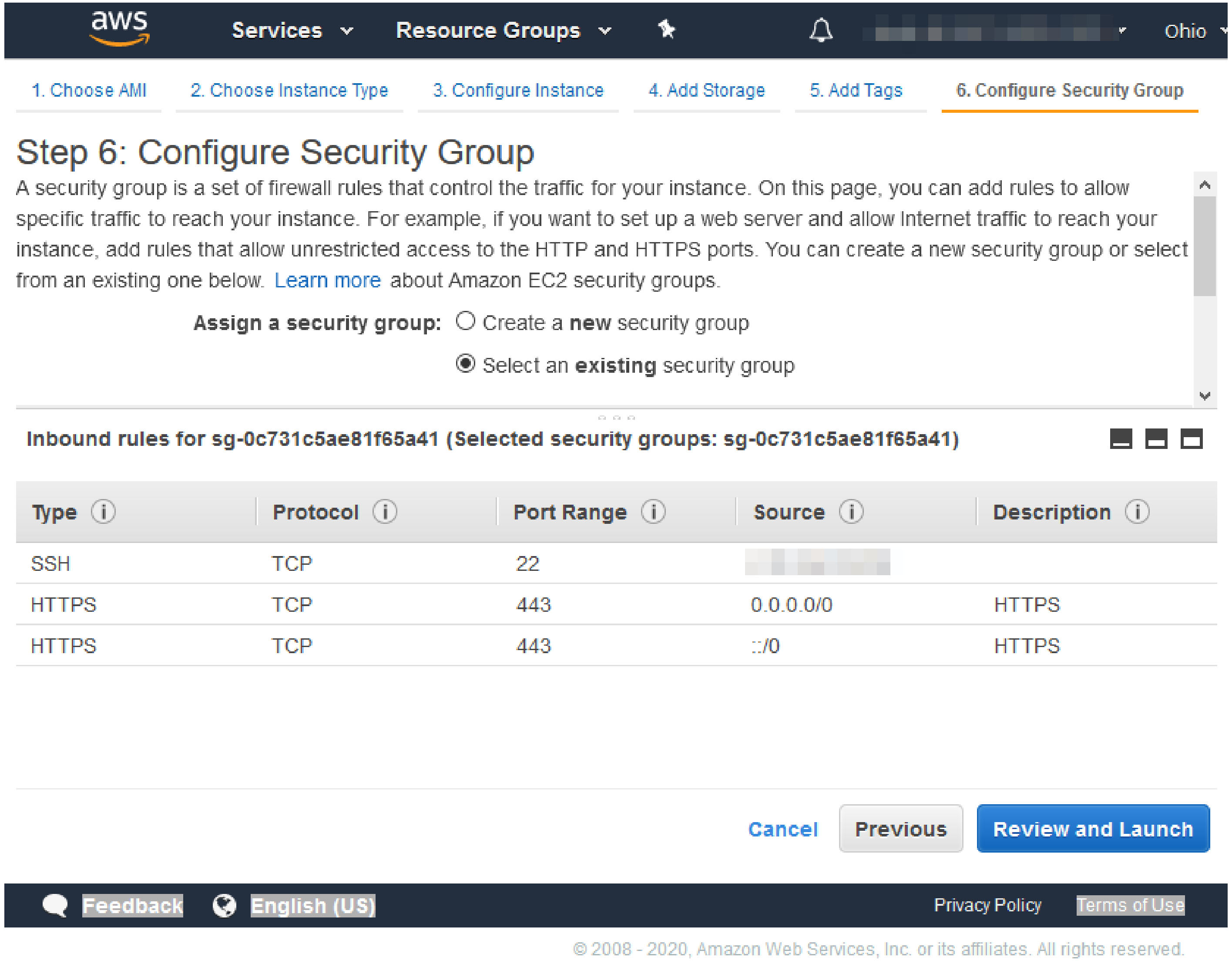
Images © 123RF.com.

VM Sprawl Avoidance

- Guest OS security
  - OS environment must still be maintained
- Rogue VMs
  - System sprawl and undocumented assets
  - Virtual machine life cycle management (VMLM)
  - Use template-based VM creation

Security Groups

- Basic stateful packet filtering for instances
- Default security group
- Custom groups
  - Custom group with no rules drops all network traffic
  - Can be assigned to multiple instances
  - Instances in the same subnet can be assigned different security groups
  - Multiple security groups can be assigned to the same instance



Screenshot used with permission from Amazon.com.

Cloud Access Security Brokers

- Mediate access to cloud services by enterprise users across all types of devices
- Implemented as proxy or via API
- Next-Generation Secure Web Gateway
  - Secure access service edge (SASE)

Summary

- ✓Cloud Computing & Virtualization Concepts
- ✓Cloud Computing Risks & Threats
- ✓Cloud Cybersecurity Solutions